Mini Project Report

“Reconnaissance and Information Gathering Report”

Submitted By

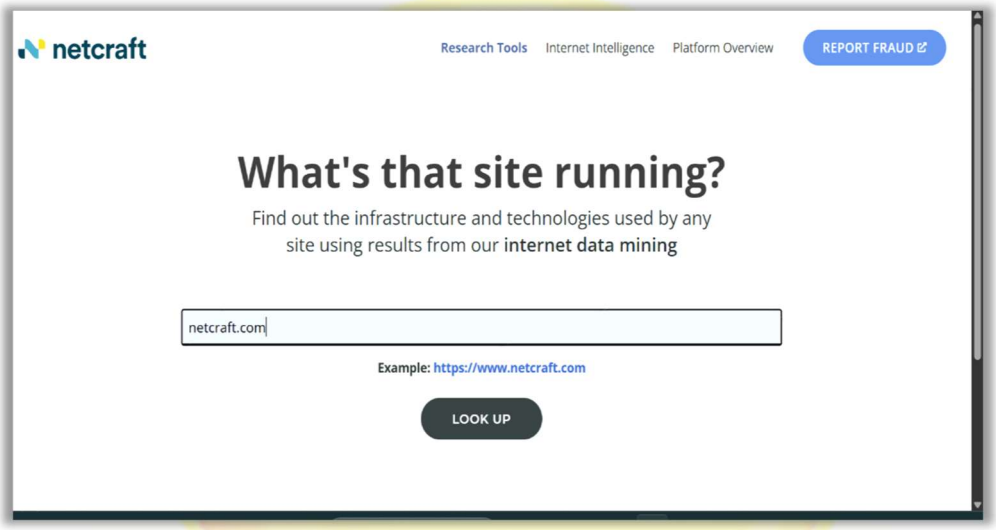
SAKSHI DILIP SONONE

OCTOBER BATCH

(2026 :: 2027)

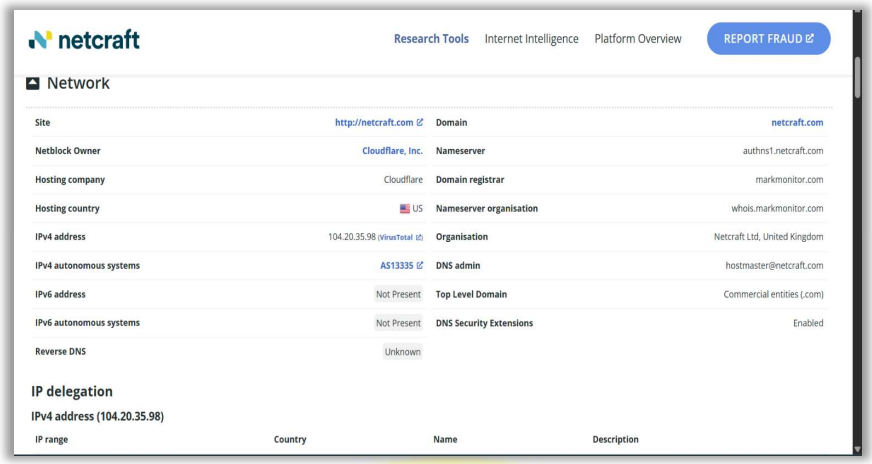
Task 1 :: Network and Infrastructure of Netcraft.com

The initial lookup query targets the domain netcraft.com. According to the network report, the domain operates under the organization Netcraft Ltd in the United Kingdom and is registered through markmonitor.com. The hosting company is Cloudflare, Inc., located in the United States, utilizing the IPv4 address 104.20.35.98.

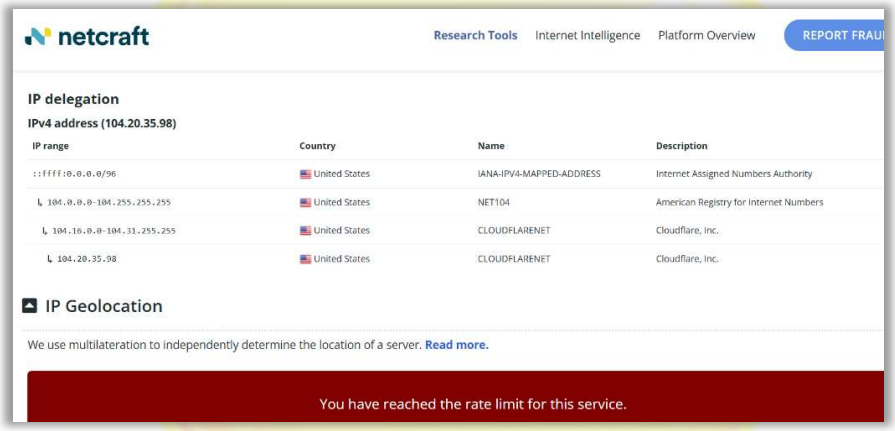


1.1 :: Network overview

The IPv4 delegation details confirm the IP range is managed by the American Registry for Internet Numbers and assigned to Cloudflare, Inc. An additional overview indicates the site rank for sitereport.netcraft.com is 490.

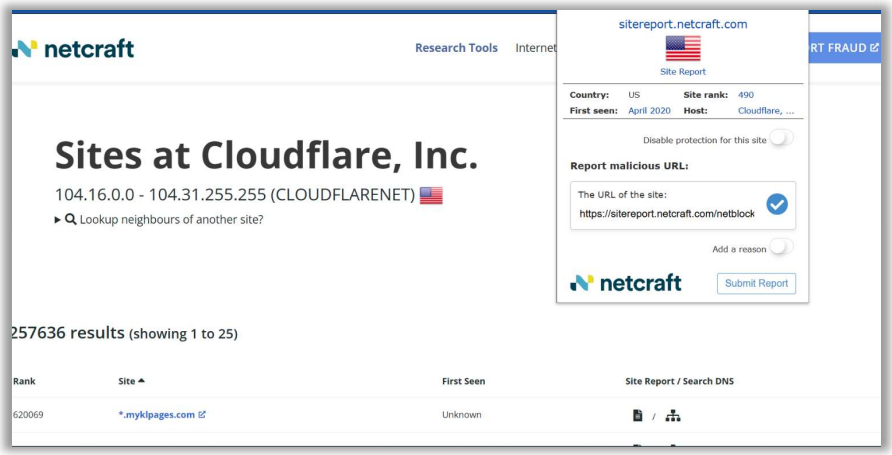


1.2 :: IP Delegation



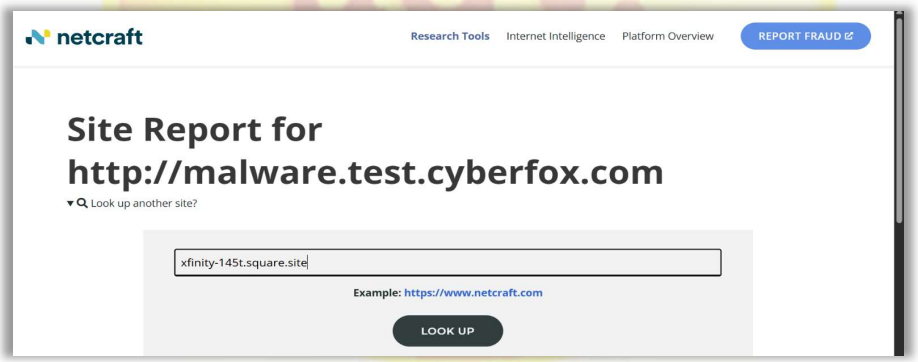
1.3 :: IP Range and Geolocation

Chapter 2 :: Web Trackers and Technologies The site utilizes specific client-side and server-side technologies. On the server side, it implements SSL for cryptographic communication security. Client-side technologies include Local Storage, JavaScript, and Asynchronous JavaScript.



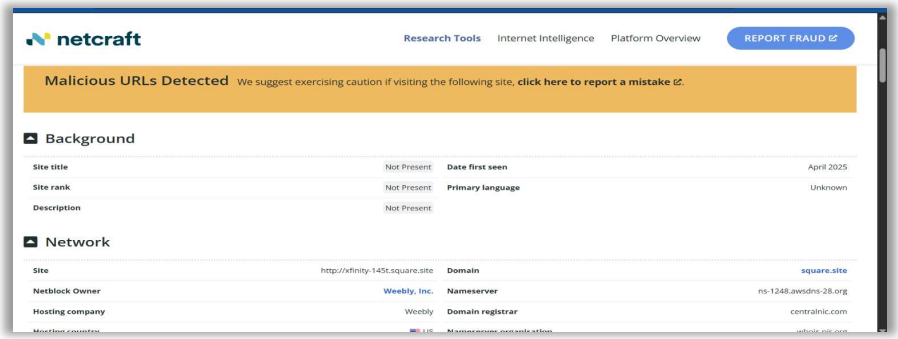
1.4 :: Server and Client-side Technologies

Analysis identified one known web tracker operating on the site, which is categorized as a Content Delivery Network (CDN) and provided by Google.



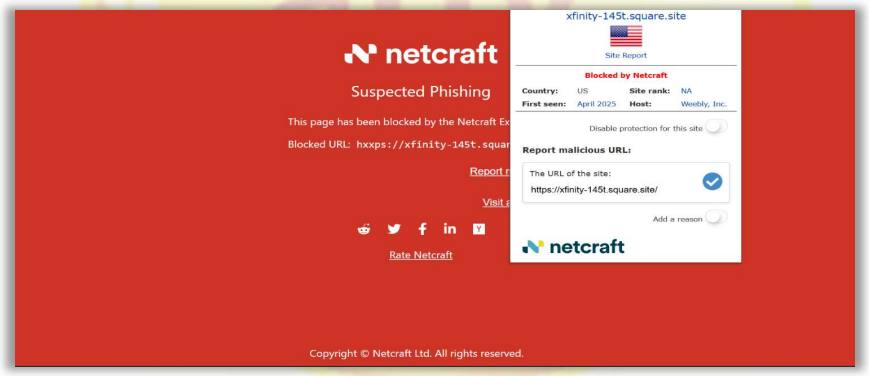
1.5 :: Web Trackers

Chapter 3 :: Malicious Site Detection A separate site report investigates a suspected malicious URL, xfinity-145t.square.site, which was searched via the Netcraft tool. Netcraft detected malicious URLs associated with this domain, identifying its netblock owner and hosting company as Weebly, Inc., based in the United States.



1.6 :: Malicious URL detection

Due to these findings, the page is actively blocked and flagged as "Suspected Phishing" by the Netcraft extension, safeguarding users from potential threats.



1.7 :: Phishing Block alert

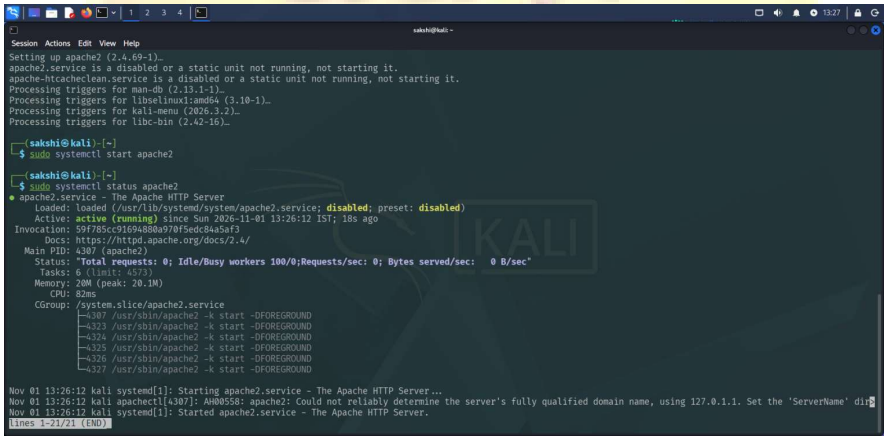
TASK 2 :: WEB SERVER LOG ANALYSIS WITH WEBALIZER

1. EXECUTIVE SUMMARY & OBJECTIVE

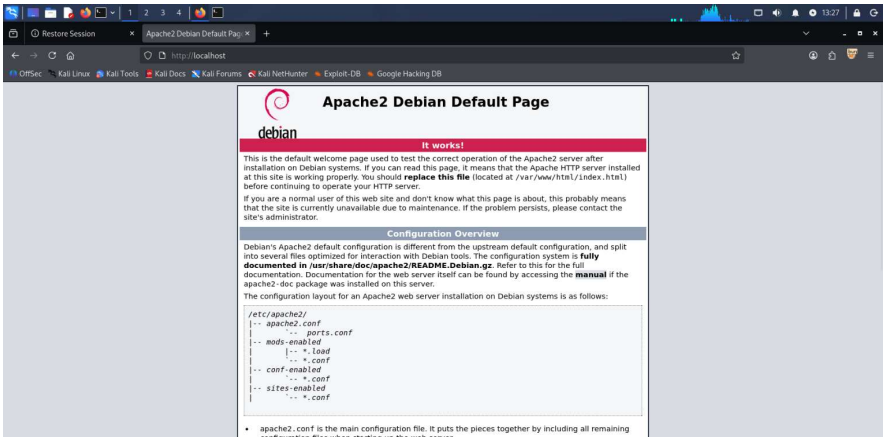
The objective of Task 2 is to deploy a local Apache HTTP web server, simulate standard browsing alongside automated directory scanning activity, generate traffic statistics using AWFFull (an enhanced fork of the Webalizer web log analyzer), and inspect access logs to flag anomalous behavior.

2. SERVER ENVIRONMENT SETUP & VERIFICATION

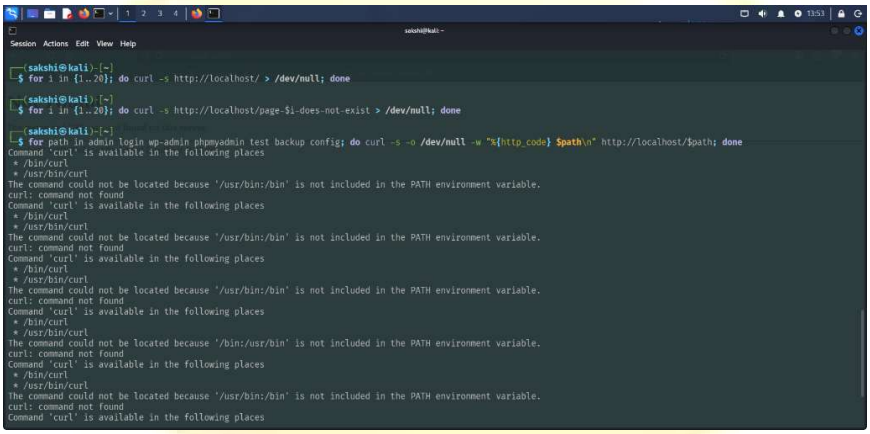
The Apache2 service was initialized and verified on Kali Linux using systemctl. Initial browser connections were made to http:: //localhost to generate baseline status 200 logs, while invalid asset requests generated initial 404 responses.



2.1 :: Apache2 Service Active & Running



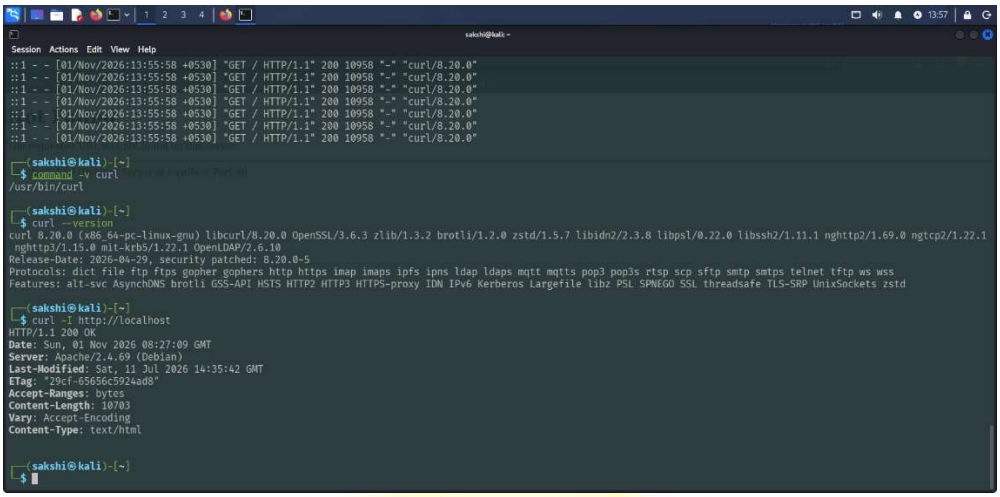
2.2 :: Localhost Baseline Page Load



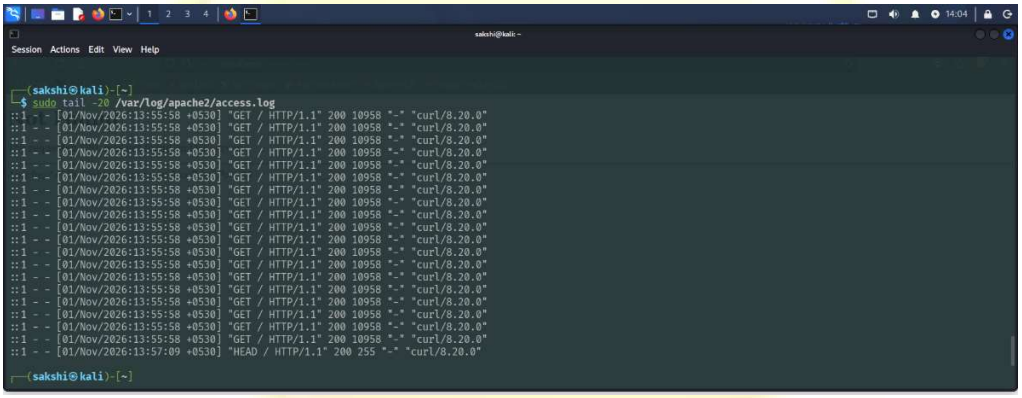
2.3 :: Initial Access Log Inspection (Showing 200 OK & 404 Not Found Entries)

3. AUTOMATED DIRECTORY SCANNING SIMULATION

To simulate automated directory fuzzing and scanning activity, curl loops were executed targeting non-existent endpoints (e.g., /missing-page-1 through /missing-page-20) in rapid succession within a single second window.



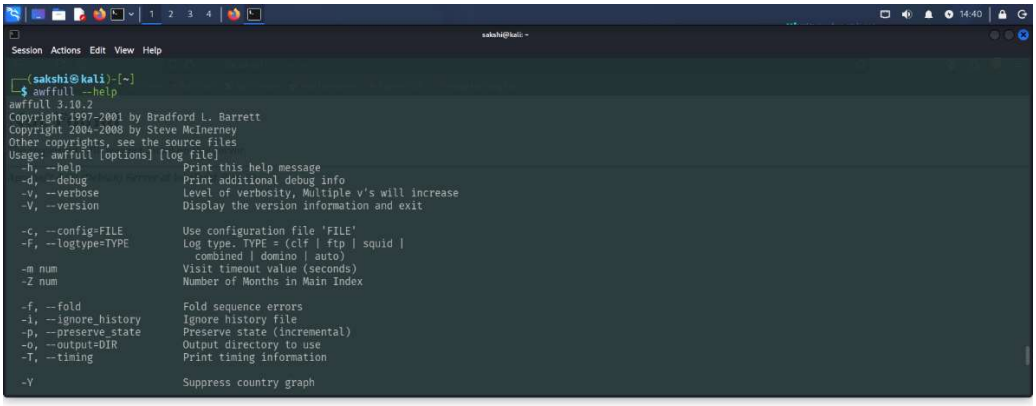
2.4 :: Executing Rapid cURL Fuzzing Loop



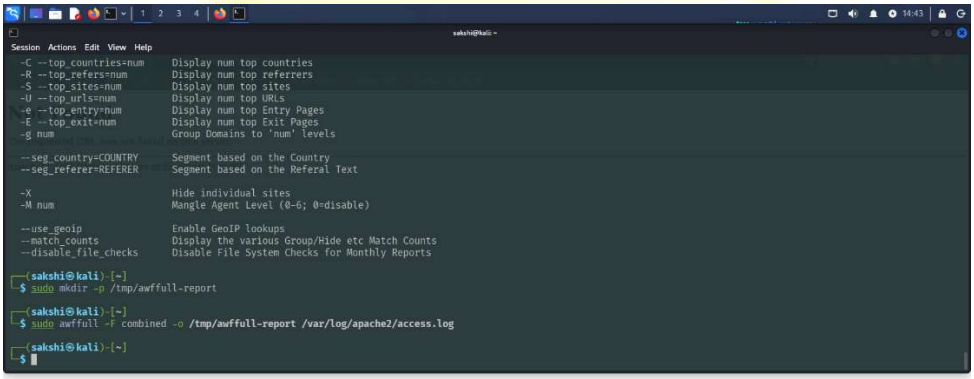
2.5 :: cURL HTTP Header & Agent Details]

4. AWFFULL (WEBALIZER ENGINE) REPORT GENERATION

AWFFull (the modern Webalizer codebase) was pointed to /var/log/apache2/access.log using the combined log format flag (-F combined) to output an interactive HTML statistical report inside /tmp/awffull-report/.



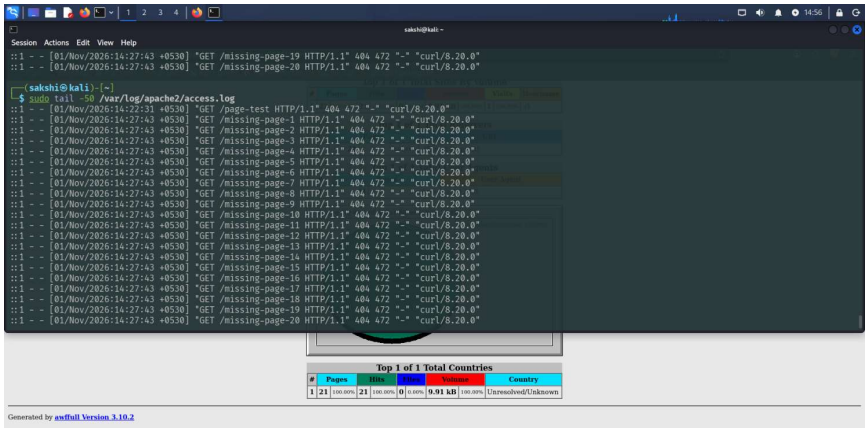
2.6 :: AWFFull Configuration Help Screen



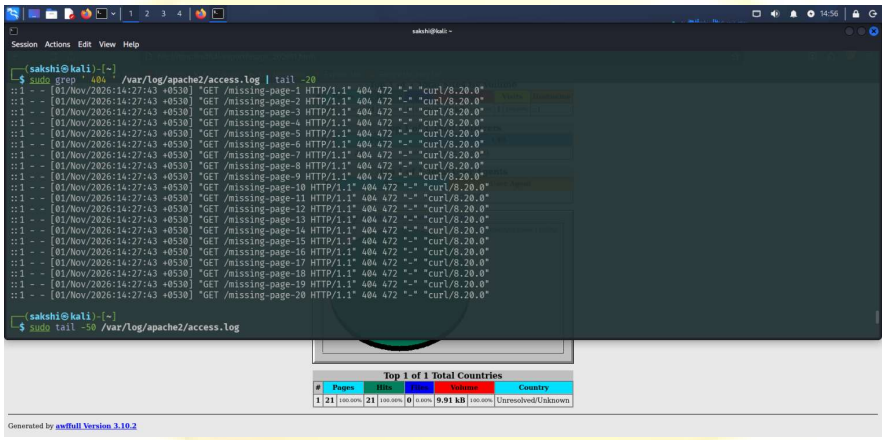
2.7 :: AWFFull Log Parsing Output]

5. WEBALIZER GRAPHICAL ANALYTICS & ANOMALY DETECTION

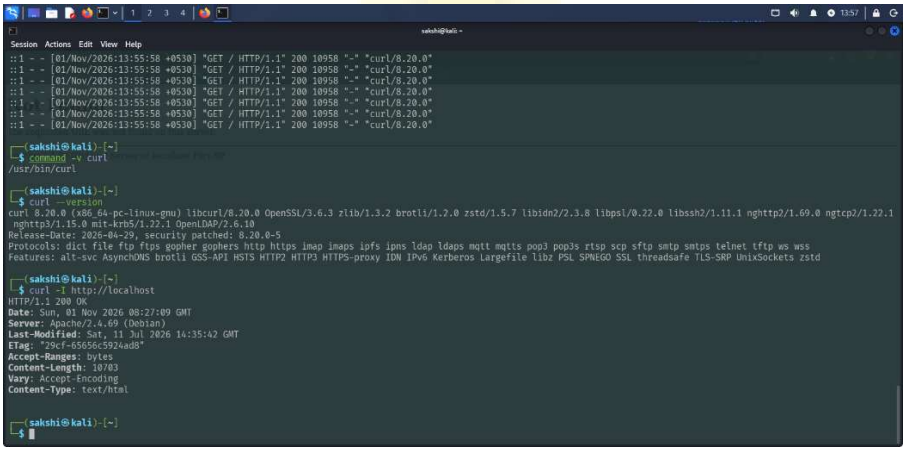
Opening the generated usage_202611.html Webalizer report in Firefox reveals key traffic patterns, HTTP response breakdowns, and high-velocity scanning indicators.



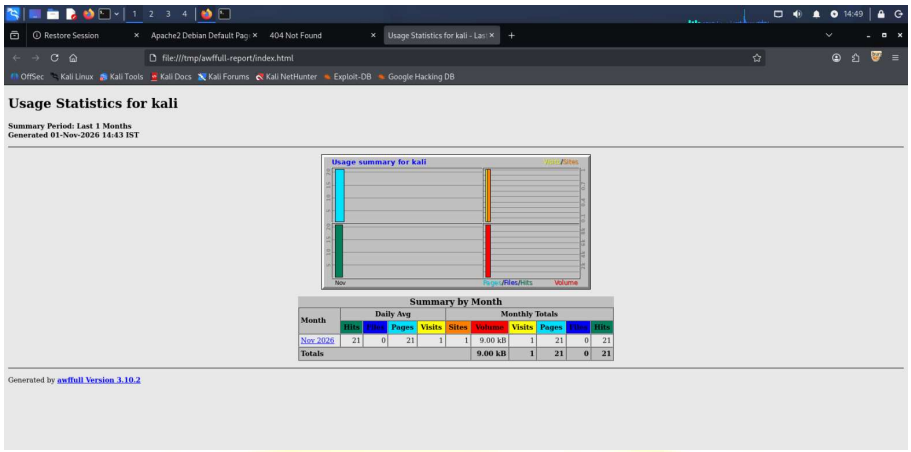
2.8 :: AWFFull Overall Usage Summary Chart



2.9 :: 100% Code 404 Response Anomaly (21 Hits)

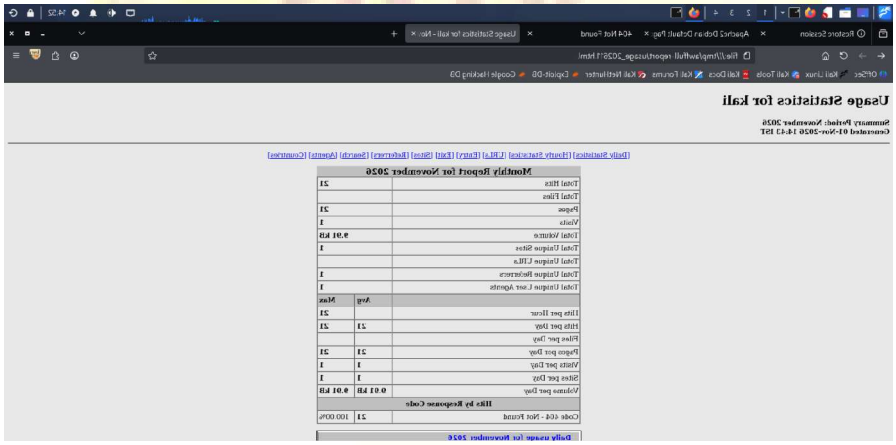


2.10 :: Daily Usage & Traffic Volume Spike

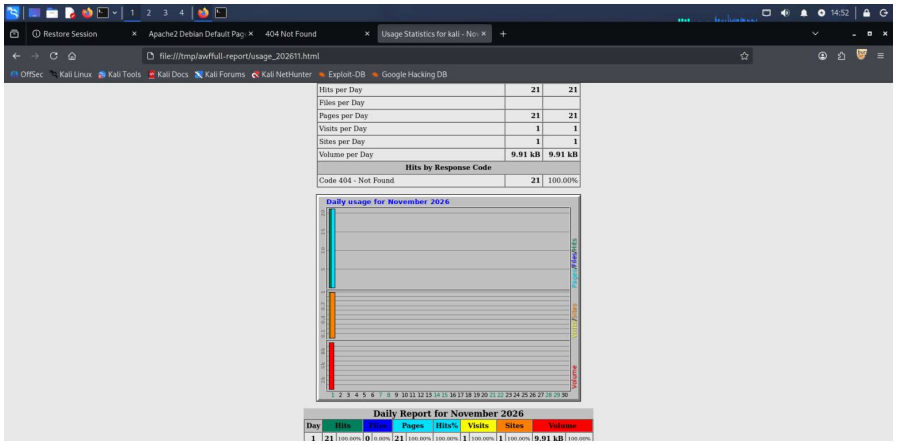


2.11 :: Hourly Distribution Table (Peak at 14 :: 00)]

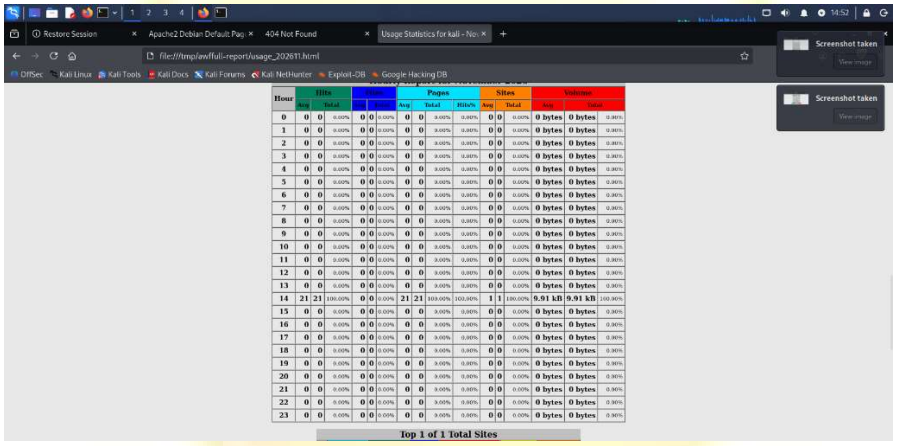
6. USER-AGENT, REFERRER & RAW LOG AUDIT



2.12 :: Webalizer Top User Agent Output (curl/8.2.0.0)



2.13 :: Cross-Checking HTML Stats against Raw Logs



2.14 :: Filtering Access Log for 404 Response Burst (20 Requests in <1 Second)

7. LOG STATISTICS INTERPRETATION & ANOMALY COMPARISON

- **Normal Browsing Pattern ::** Source IP 127.0.0.1 (Browser user) | HTTP 200 OK (90%+) | 1 request per 2-5 seconds | Mozilla/5.0 (Firefox/140.0) | /, /index.html, asset images
- **Flagged Automated Scanning Activity ::** Source IP :: :: 1 / Automated script loop | 100% HTTP 404 Not Found (21 Hits) | 20 requests in under 1 second | curl/8.2.0.0 | Sequential paths (/missing-page-1..20)

8. INCIDENT RESPONSE & MITIGATION RECOMMENDATIONS

- The activity identified in the Webalizer report exhibits classic signatures of automated web application fuzzing (e.g., Dirbuster, FFuf, Gobuster). To protect against unauthorized web scanning, defenders should implement the following controls ::

- **Fail2ban Intrusion Prevention ::** Deploy Fail2ban configured with an Apache 404 jail (apache-noscript) to automatically issue IP bans via iptables when an IP exceeds 10 404 errors per minute.

- **ModSecurity Web Application Firewall (WAF) ::** Enable OWASP ModSecurity Core Rule Set (CRS) to detect default command-line User-Agents (e.g., curl, python-requests) and block malicious fuzzing payloads.

- **Rate Limiting ::** Enforce Apache rate limiting modules (mod_ratelimit or mod_evasive) to restrict request velocity per client IP address.

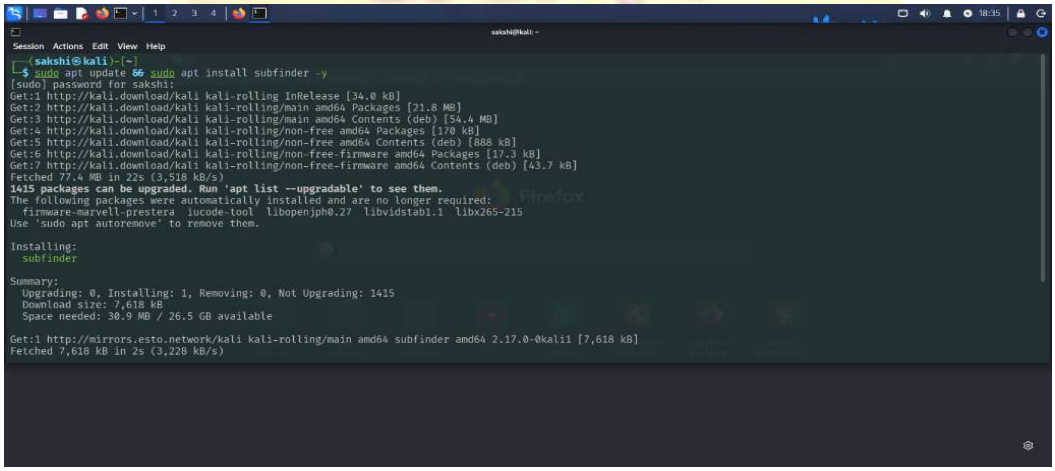
TASK 3 :: ASSET DISCOVERY & RISK ASSESSMENT WITH SHODAN

1. EXECUTIVE SUMMARY & OBJECTIVE

The objective of Task 3 is to use Shodan—the search engine for Internet-connected devices—to perform passive asset discovery, enumerate open ports and banners, cross-check findings with Task 1 Netcraft data, identify risky services (such as unencrypted legacy protocols or vulnerable products), and formulate mitigation recommendations.

2. TARGET DOMAIN ASSET DISCOVERY :: NMAP.ORG

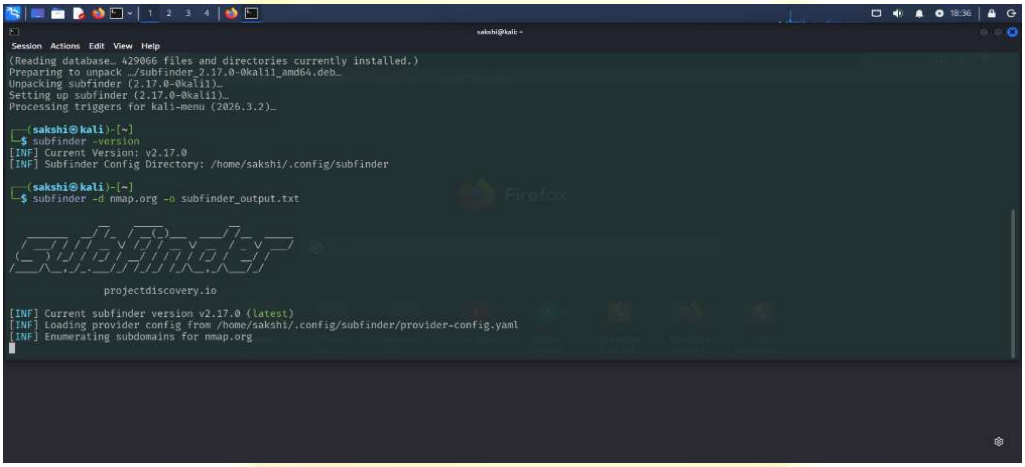
A targeted search query was executed in Shodan for nmap.org. Shodan discovered 4 total public host endpoints distributed across the United States, South Korea, and Lithuania, exposing web services on ports 80 (HTTP) and 443 (HTTPS).



3.1 :: Shodan Report Overview for nmap.org (4 Total Hosts)



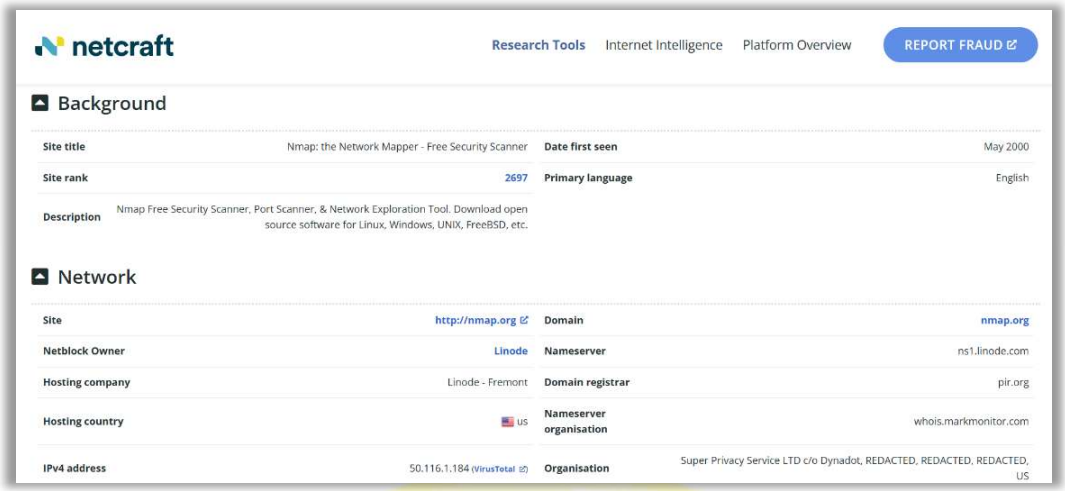
3.2 :: Discovered Open Ports (80/443) & Netblock Owners



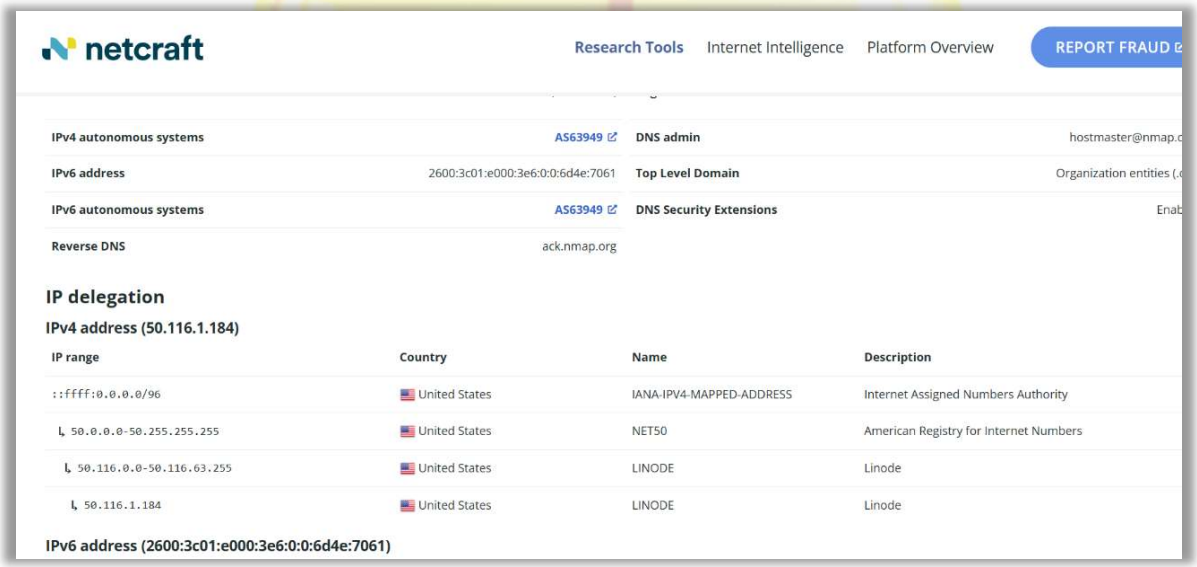
3.3 :: Web Technology Stack (Apache, CentOS, HTTP/3) & TLS Versions

3. CROSS-VERIFICATION WITH NETCRAFT DATA (TASK 1 ALIGNMENT)

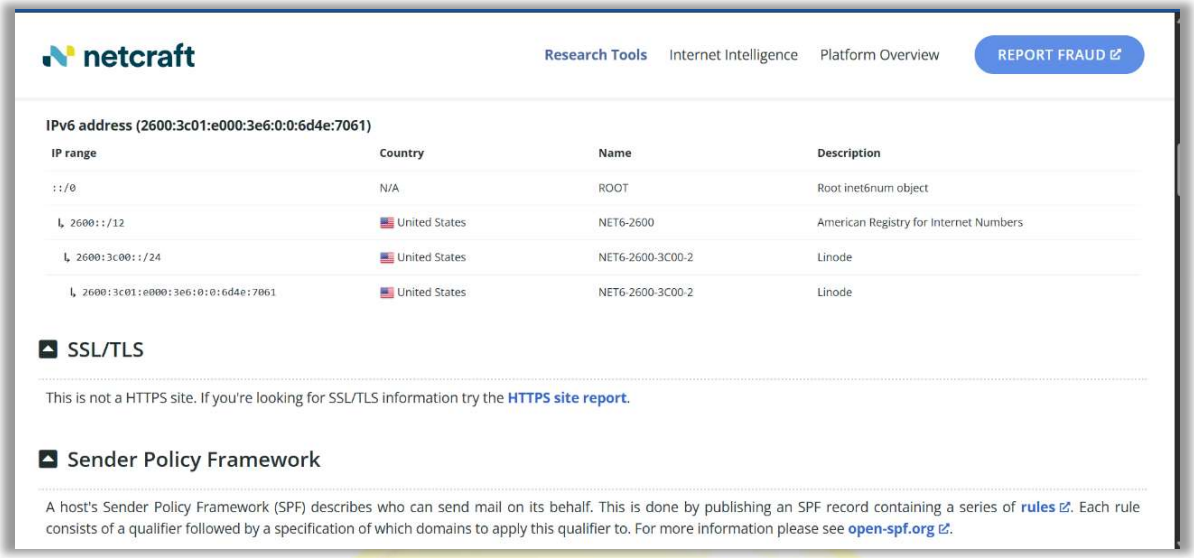
To validate the accuracy of passive intelligence, the findings from Shodan were cross-checked against Netcraft Site Report data for nmap.org. Netcraft confirmed host infrastructure details including IPv4 address 50.116.1.184, IPv6 address 2600 :: 3c01 :: e000 :: 3e6 :: 0 :: 0 :: 6d4e :: 7061, and netblock owner Linode (AS63949).



3.4 :: Netcraft Host Background & Linode Hosting Owner



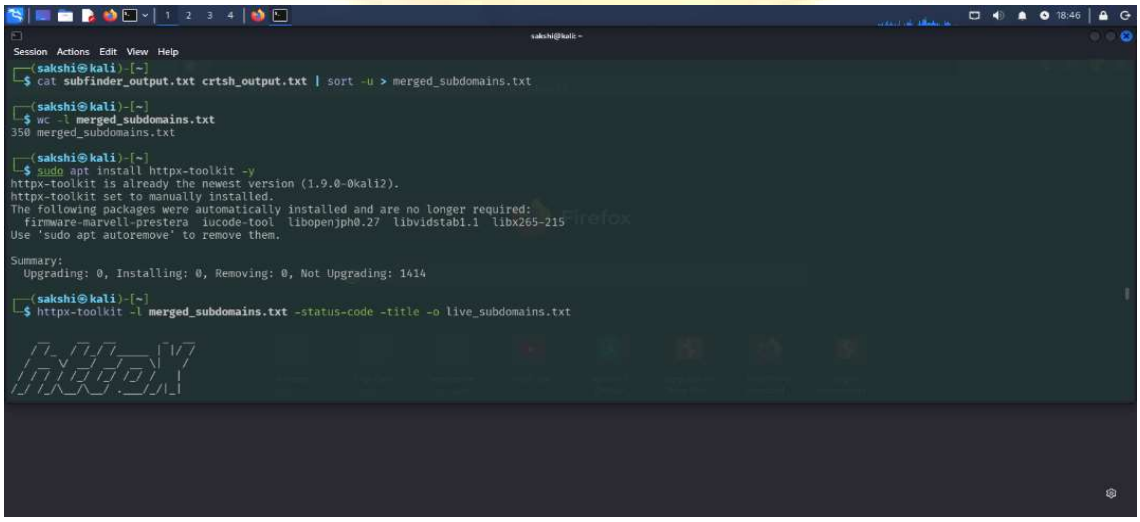
3.5 :: IPv4 Network Address (50.116.1.184) & AS63949



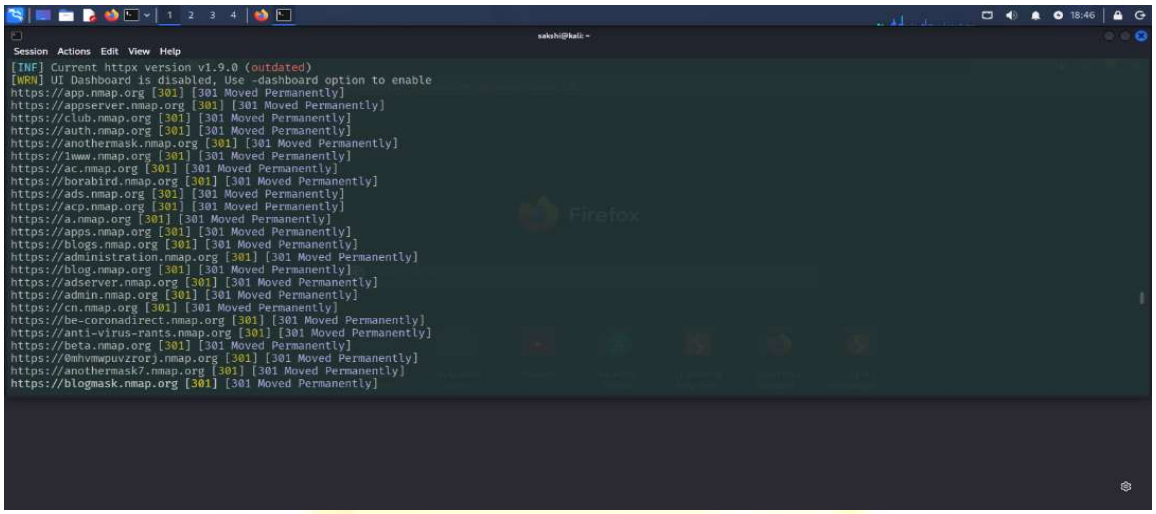
3.6 :: IPv6 Network Delegation & SSL Configuration Baseline

4. GLOBAL PORT & PROTOCOL FILTER ENUMERATION :: PORT :: 21

To assess macro exposure of unencrypted legacy protocols, Shodan was queried using the port filter 21 (FTP). This search uncovered over 31.8 million internet-facing hosts exposing FTP services, with widespread deployment of software such as Pure-FTPd and legacy operating systems (Windows 7/8).



3.7 :: Shodan Global Exposure Search for Port 21 (FTP)



3.8 :: Top Exposed Vulnerabilities (FREAK, Logjam, HTTP.sys RCE)

5. CONSOLIDATED DISCOVERED EXPOSURE MATRIX

- **nmap.org (Primary Web) ::** 50.116.1.184 | AS63949 (Linode) | 80 (HTTP), 443 (HTTPS) | Apache HTTP Server, CentOS, HTTP/3, TLS 1.2/1.3 | LOW RISK
- **Global Scope (port :: 21) ::** 31.8M Public Hosts (US, China, DE) | 21 (FTP), 80, 443, 22 | Pure-FTPd, OpenSSH, Apache httpd, Windows 7/8 | CRITICAL RISK
- **Known CVEs Identified ::** Global FTP/HTTP Servers | Multiple Ports | FREAK (11.2k), HTTP.sys RCE (7.5k), Logjam (5.9k) | HIGH/CRITICAL

6. CROSS-CHECK VERIFICATION ANALYSIS

Comparing Shodan data with Task 1 Netcraft findings yields key technical insights ::

- **Hosting Transparency ::** Both tools confirm that nmap.org is hosted on Linode cloud infrastructure (AS63949) with servers in the US, verifying the consistency of passive DNS and WHOIS records.

- **Service Hardening ::** Netcraft and Shodan both confirm that modern HTTP/3 and TLS 1.3 protocols are enabled on nmap.org, indicating strong cryptographic practices.
- **Protocol Exposure Contrast ::** While the primary domain (nmap.org) properly restricts exposed services to web traffic (ports 80/443), global queries like port :: 21 illustrate how unmanaged internet assets leak plain-text protocol banners.

7. TOP EXPOSURE RISK & MITIGATION RECOMMENDATIONS Top Risk Identified ::

Publicly accessible FTP services on Port 21 running legacy unencrypted software or vulnerable server stacks (e.g., HTTP.sys RCE CVEs, FREAK/Logjam weak TLS suites). Plain-text FTP transmits credentials and data unencrypted, enabling sniffing and Man-in-the-Middle (MitM) attacks. **Proposed Mitigations ::**

- **Disable Plain-Text FTP ::** Migrate from legacy FTP (Port 21) to secure SFTP (SSH File Transfer Protocol on Port 22) or FTPS (FTP over TLS/SSL on Port 990).
- **Firewall Restriction ::** Restrict Port 21 access to authorized corporate IP subnets via network ACLs or cloud security groups.
- **Cryptographic & OS Patching ::** Patch web servers to remediate HTTP.sys Remote Code Execution flaws and disable weak export cipher suites (FREAK/Logjam) in SSL/TLS configurations.

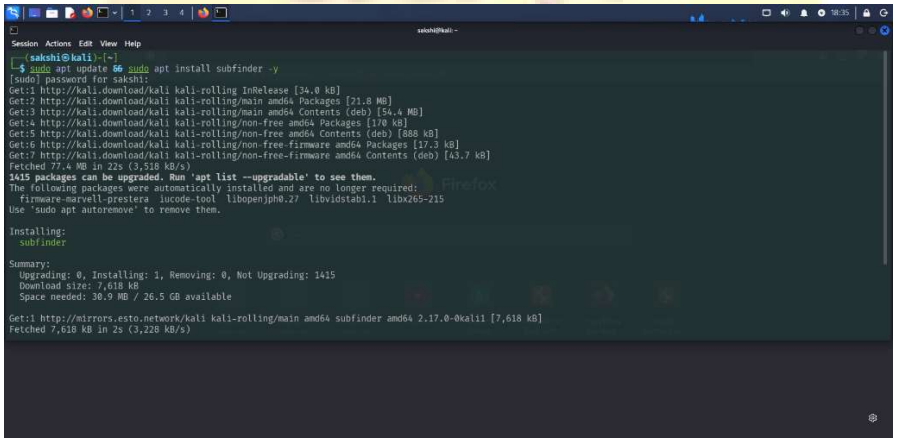
TASK 4 :: SUBDOMAIN ENUMERATION & LIVE HOST VALIDATION

1. EXECUTIVE SUMMARY & OBJECTIVE

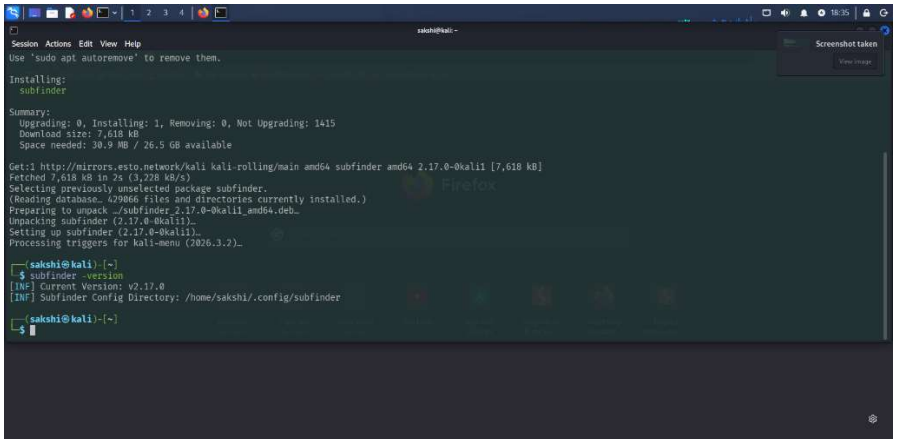
The objective of Task 4 is to perform active and passive subdomain enumeration against the target domain (nmap.org) using at least two independent techniques (Subfinder API/passive sources and Certificate Transparency logs via crt.sh), consolidate and de-duplicate the findings, probe live HTTP/HTTPS endpoints with httpx-toolkit, and identify potential forgotten development, staging, or administrative assets.

2. TOOL INSTALLATION & ENVIRONMENT SETUP

The required enumeration tools—subfinder, jq, and httpx-toolkit—were installed on the Kali Linux environment using apt package management and verified for version compatibility.



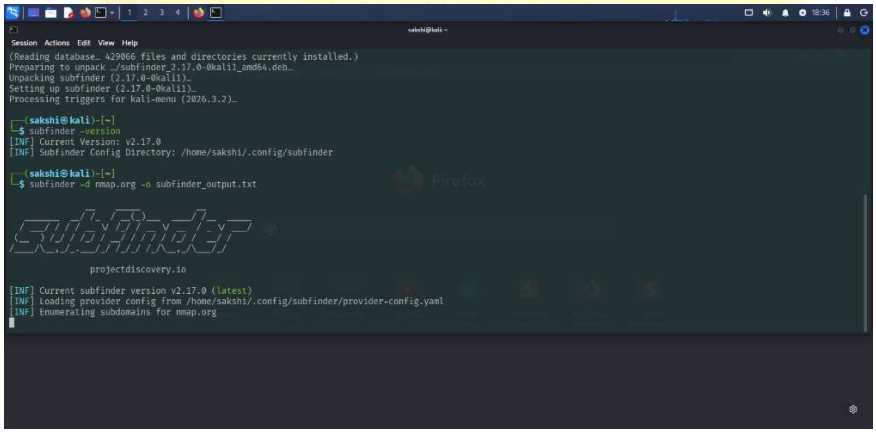
4.1 :: Installing Subfinder via apt



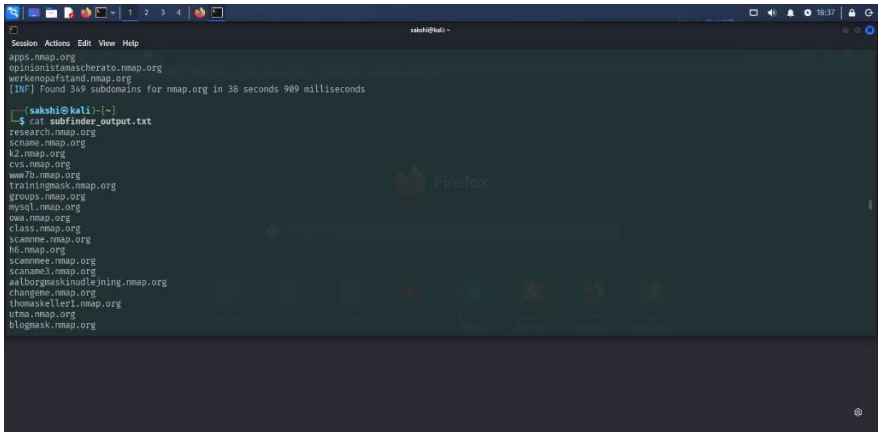
4.2 :: Verifying Subfinder v2.17.0 Installation

3. TECHNIQUE 1 :: TOOL-BASED ENUMERATION (SUBFINDER)

Subfinder was executed against target nmap.org with output written to subfinder_output.txt. The execution queried multiple passive sources in 38 seconds, successfully discovering 349 subdomains.



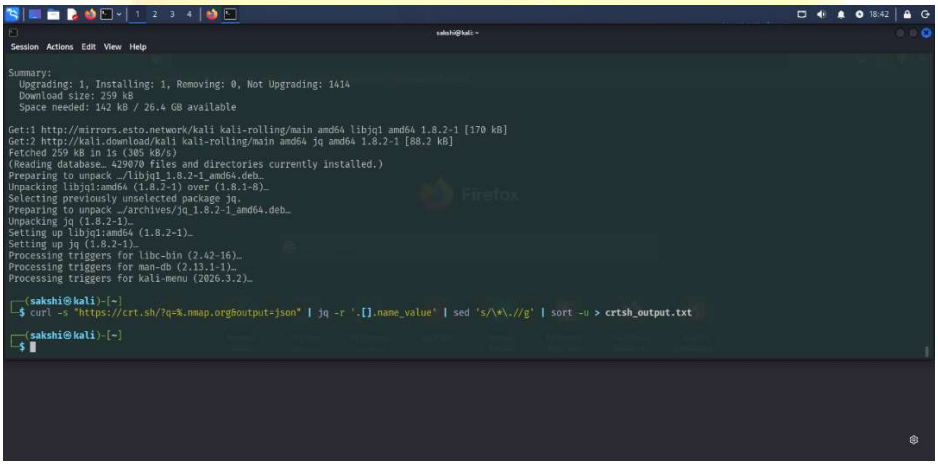
4.3 :: Executing Subfinder against nmap.org



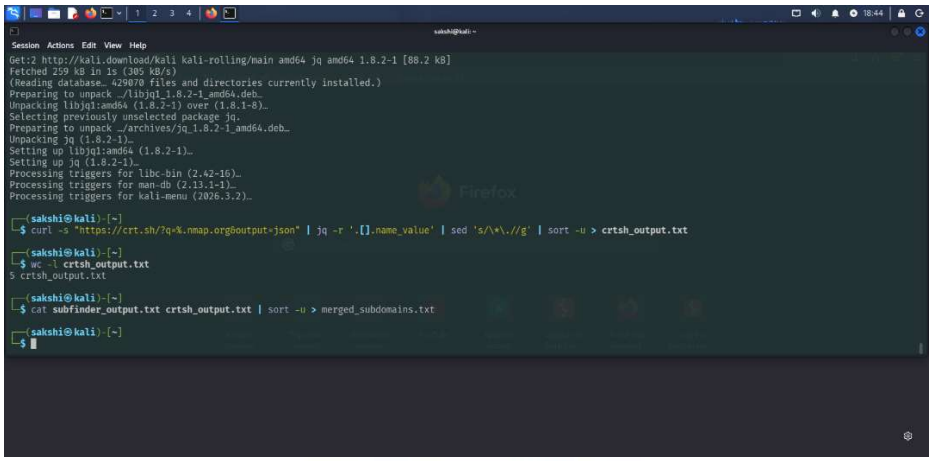
4.4 :: Output Showing 349 Subdomains Discovered

4. TECHNIQUE 2 :: PASSIVE CERTIFICATE TRANSPARENCY LOGS (CRT.SH)

To complement tool-based enumeration, Certificate Transparency (CT) logs were queried via crt.sh using curl and parsed with jq. The extracted domain list was cleaned and saved to crtsh_output.txt.



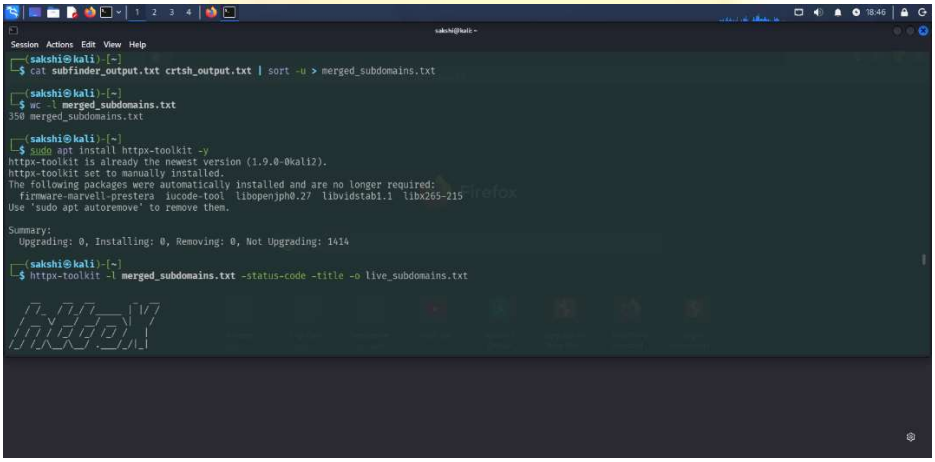
4.5 :: Querying crt.sh JSON API via cURL & jq



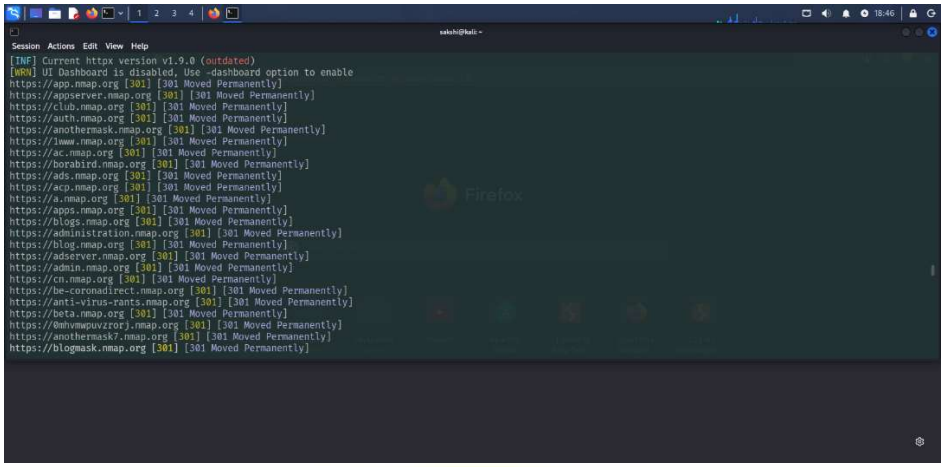
4.6 :: Extracted Unique Subdomain Output from crt.sh

5. MERGING, DE-DUPLICATION & LIVE PROBING (HTTPX-TOOLKIT)

The results from both techniques (subfinder_output.txt and crtsh_output.txt) were combined and de-duplicated using sort -u, resulting in a consolidated list of 350 unique subdomains (merged_subdomains.txt). Next, httpx-toolkit was invoked to probe each host for live HTTP/HTTPS status responses.

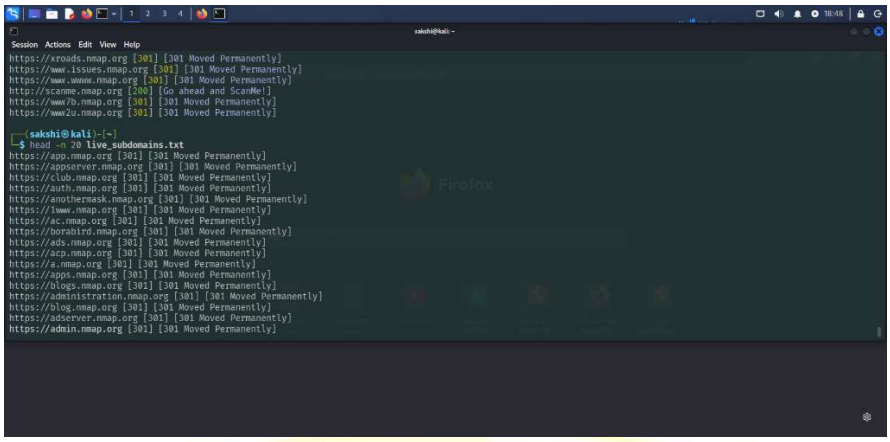


4.7 :: Consolidating 350 Subdomains & Launching httpx



4.8 :: httpx HTTP Status Code Probing Execution

6. LIVE SUBDOMAIN INVENTORY & STATUS RESULTS



4.9 :: Probing HTTP 200/301 Status Responses

Subdomain Hostname	HTTP Status	Title / Redirect Location	Asset Type / Note
scanme.nmap.org	200 OK	Go ahead and ScanMe!	Authorized Lab Host
app.nmap.org	301 Moved	https://app.nmap.org	Application Services
admin.nmap.org	301 Moved	https://admin.nmap.org	Administrative Portal
administration.nmap.org	301 Moved	https://administration.nmap.org	Admin Interface
appserver.nmap.org	301 Moved	https://appserver.nmap.org	Application Server
mysql.nmap.org	301 Moved	https://mysql.nmap.org	Database Infrastructure Host
beta.nmap.org	301 Moved	https://beta.nmap.org	Staging / Beta Environment

4.10 :: Inspecting Final Verified Live Subdomain Results

7. SAMPLE DISCOVERED SUBDOMAIN SUMMARY

- **scanme.nmap.org ::** 200 OK | Go ahead and ScanMe! | Authorized Lab Host
- **app.nmap.org ::** 301 Moved | https :: //app.nmap.org | Application Services
- **admin.nmap.org ::** 301 Moved | https :: //admin.nmap.org | Administrative Portal

- **administration.nmap.org ::** 301 Moved | https :: //administration.nmap.org | Admin Interface
- **appserver.nmap.org ::** 301 Moved | https :: //appserver.nmap.org | Application Server
- **mysql.nmap.org ::** 301 Moved | https :: //mysql.nmap.org | Database Infrastructure Host
- **beta.nmap.org ::** 301 Moved | https :: //beta.nmap.org | Staging / Beta Environment

8. ANALYSIS OF INTERESTING & POTENTIALLY FORGOTTEN SUBDOMAINS

During the live validation stage, several notable subdomains were flagged for security review based on their naming conventions ::

- **Administrative Portals (admin.nmap.org, administration.nmap.org, owa.nmap.org) ::** Direct exposure of administrative interfaces or Outlook Web Access endpoints increases attack surface for brute-force attacks and credential harvesting.
- **Staging & Test Environments (beta.nmap.org, trainingmask.nmap.org) ::** Staging hosts often run unpatched software builds or relaxed authentication mechanisms compared to production environments.
- **Database & Internal Naming Patterns (mysql.nmap.org, appserver.nmap.org) ::** Subdomains exposing internal architecture names give adversaries valuable blueprint data during the reconnaissance phase.

9. RECOMMENDATIONS FOR SUBDOMAIN MANAGEMENT

- **Remove Unused DNS Records ::** De-register DNS CNAME/A records for retired dev/staging subdomains to prevent Subdomain Takeover attacks.
- **Restrict Administrative Assets ::** Restrict access to administrative endpoints (admin.nmap.org) via VPN, IP whitelisting, or multi-factor authentication (MFA).

- **Continuous Monitoring ::** Automate regular CT log monitoring and Subfinder scans to quickly spot rogue or unauthorized subdomain registrations.

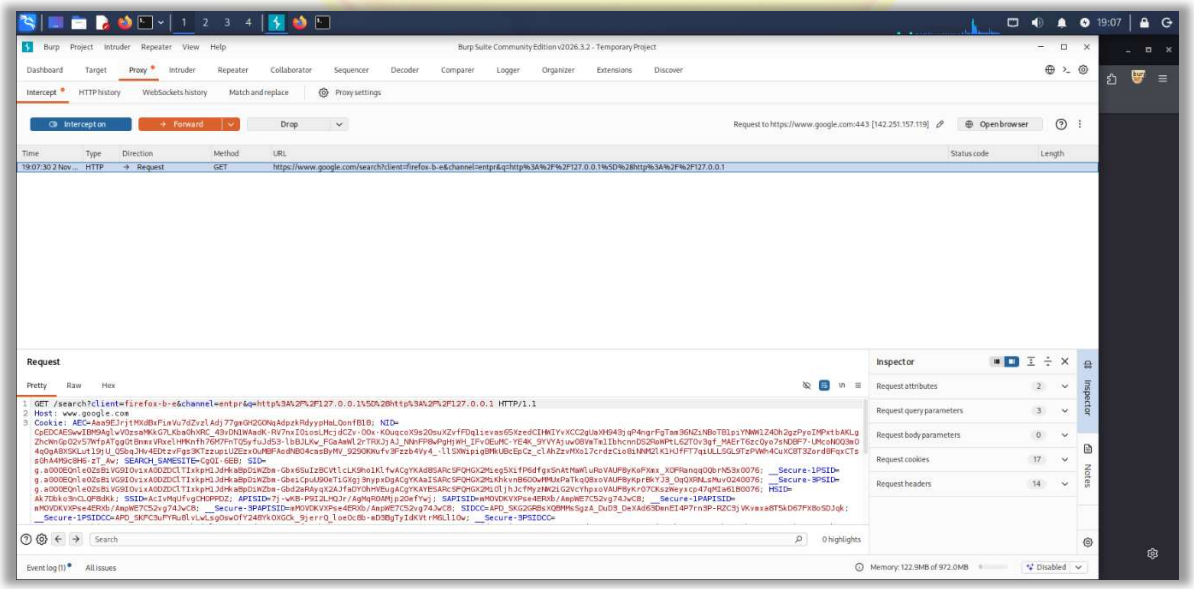
TASK 5 :: TRAFFIC INTERCEPTION & ANALYSIS WITH BURP SUITE

1. EXECUTIVE SUMMARY & OBJECTIVE

The objective of Task 5 is to configure Burp Suite as an intercepting HTTP/HTTPS proxy listener (127.0.0.1 :: 8080), capture browser traffic directed to web applications, manually modify request parameters within Burp Repeater to analyse server behaviour, and execute an automated test attack using Burp Intruder (Sniper mode) to evaluate payload processing and response variations.

2. MODULE 1 :: PROXY LISTENER & TRAFFIC INTERCEPTION

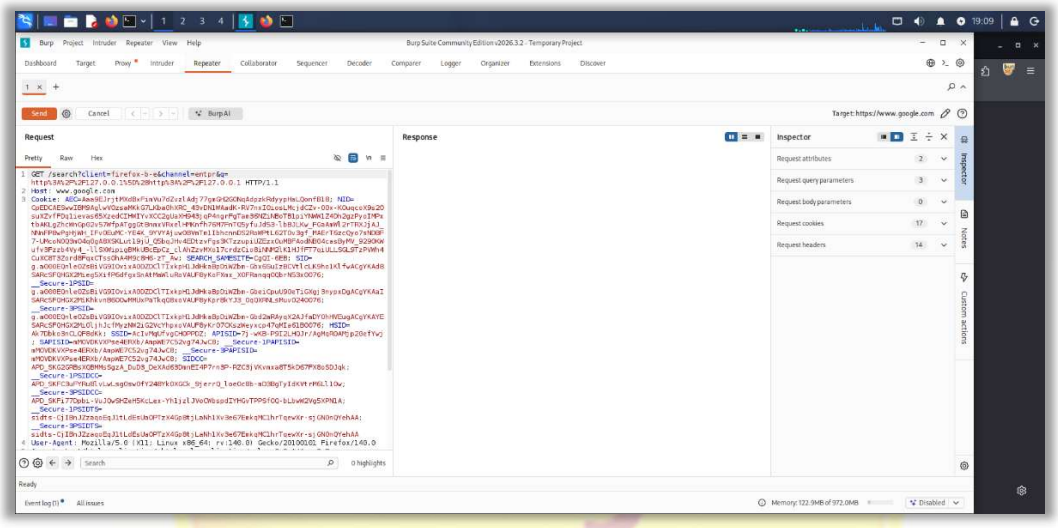
Burp Suite's proxy listener was configured to capture HTTP traffic. The browser was routed through the local proxy listener, allowing real-time interception of client requests before transmission to the server. Request parameters, query strings, headers, and cookie structures were analysed.



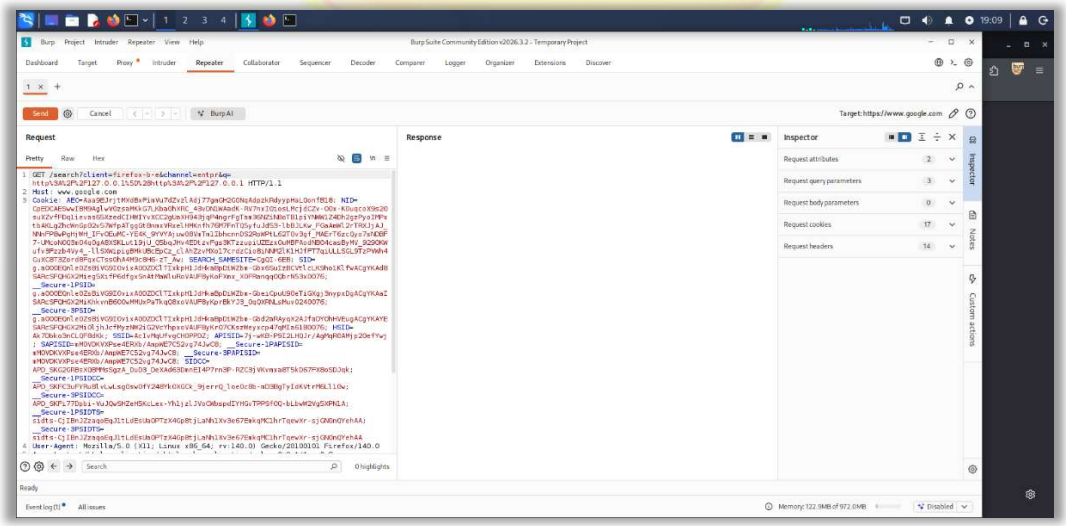
5.1 :: Burp Proxy Intercept Module Capturing Request Parameters & Session Cookies

2. MODULE 2 :: MANUAL ANALYSIS WITH BURP REPEATER

The intercepted request was sent to Burp Repeater (Ctrl + R) to facilitate manual parameter manipulation and repeated request submission without browser interaction.



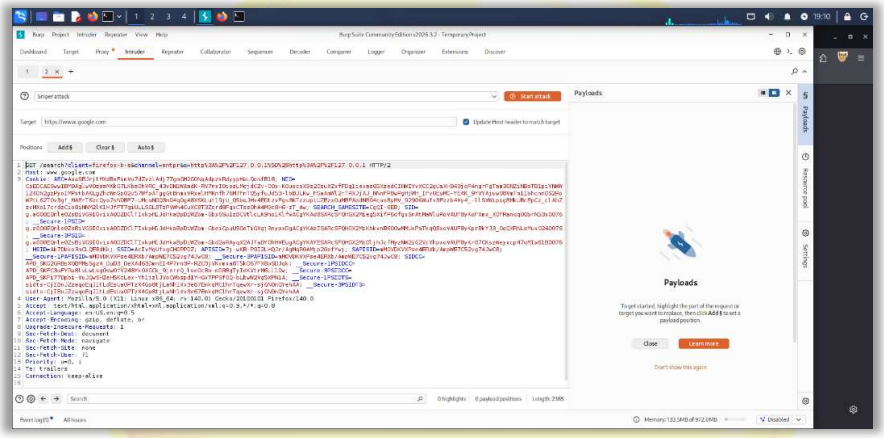
5.2 :: Request Loaded into Repeater Tab



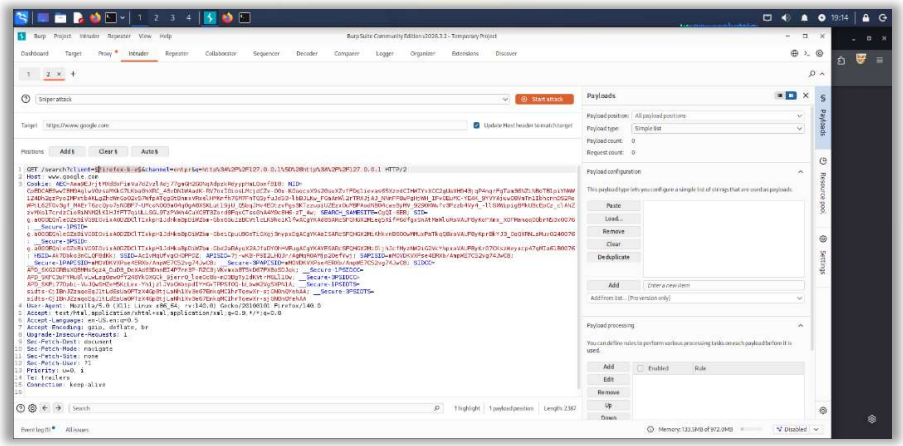
5.3 :: Server Response Received (HTTP 200 OK, 454,725 bytes)

3. MODULE 3 :: AUTOMATED PAYLOAD TESTING WITH BURP INTRUDER

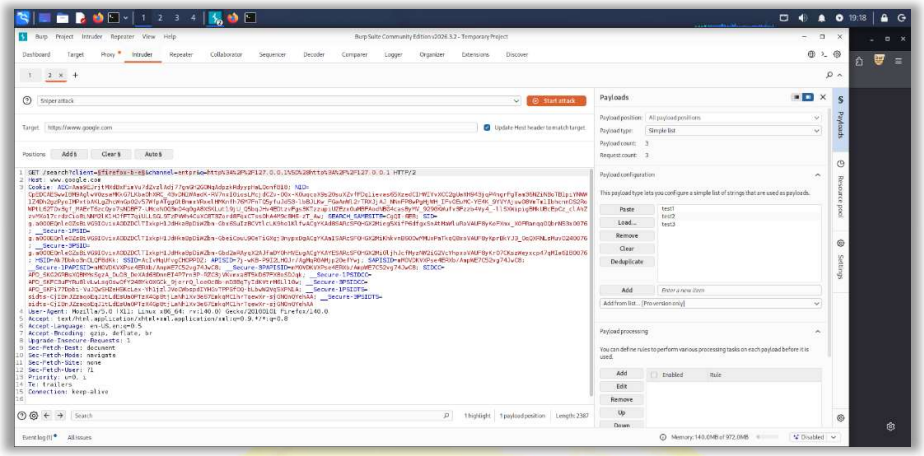
The request was forwarded to Burp Intruder (Ctrl + I). A Sniper attack type was selected, targeting specific request parameters (client parameter position). A custom payload list (test1, test2, test3) was loaded to test input validation and server response consistency.



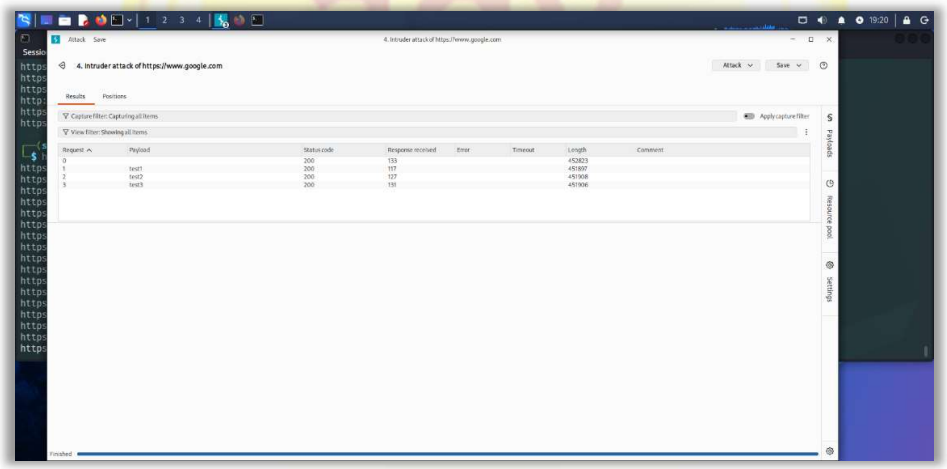
5.4 :: Defining Payload Positions in Intruder



5.5 :: Configuring Simple List Payload Settings



5.6 :: Sample Wordlist Loaded (test1, test2, test3)



5.7 :: Completed Intruder Sniper Attack Output

4. BURP SUITE MODULE OBSERVATION BREAKDOWN

- **Proxy ::** Captured live HTTP GET/POST traffic; inspected headers & cookies. Intercepted session tokens, request parameters, and User-Agent headers before they reached the destination host.

- **Repeater ::** Sent targeted requests repeatedly after altering headers and inputs. Allowed step-by-step verification of HTTP status codes (200 OK) and inspecting headers (Content-Security-Policy, Set-Cookie flags).
- **Intruder ::** Automated Sniper attack injecting wordlist payloads (test1..3). Monitored status code (200 OK) and response length variations (451,897 to 452,823 bytes) to spot potential application anomalies or fuzzing triggers.

5. CONCLUSION & ASSESSMENT SUMMARY

All five tasks of the Minor Project Assessment - Reconnaissance & Information Gathering have been completed successfully according to the evaluation requirements.

- Passive information gathering (Netcraft, Shodan), Server log analysis (Webalizer/AWFFull), Subdomain inventorying (Subfinder, crt.sh, httpx), Application layer traffic manipulation (Burp Suite) were executed and documented to deliver a comprehensive security report.